

****NEWSLETTER N. 514 of November 27, 2023****

****Health dossier, Privacy Authority: accessible only for care reasons****

****Insurance: heirs can know the beneficiaries of policies****

****Civil status certificates at the Post Office, Privacy Authority approval****

****Privacy Authority warns osteopath: in thesis, health data of a patient****

****Health dossier, Privacy Authority: accessible only for care reasons****

****A Local Health Authority fined €40,000****

A €40,000 fine was imposed by the Privacy Authority on a Local Health Authority (Asl) for failing to configure the corporate health dossier in such a way as to prevent authorized personnel from viewing the health status of colleagues for purposes other than care.

The Authority intervened following a complaint from a nurse who was both a patient and an employee of the Asl. It was found that those responsible for organizing the shifts in the department where she worked had freely accessed the health dossier of colleagues during the lockdown to check for potential Covid-19 positivity and plan hospital attendance. According to the Asl, this practice was necessary to know which human resources were available, considering that during the pandemic, a large part of the staff was on sick leave due to Covid.

In its ruling, the Authority emphasized that access to the health dossier is permitted only for doctors and personnel who are treating a patient, and not for organizational and administrative needs, even in cases where, as in this specific instance, the Asl acts as both employer and health authority responsible for the individual concerned. The use of the dossier to organize hospital shifts is, moreover, an ineffective method as this tool is bound by the consent of the individual and is inherently incomplete given that the individual may choose to obscure certain data and documents, including the results of Covid tests.

During the investigation, the Authority also established that access was possible because the configuration of the corporate health dossier did not provide for access limits, nor systems of alerts and monitoring aimed at signaling any unlawful conduct by employees. In addition to imposing the fine, the Authority ordered the hospital to adopt new procedures and organizational measures to ensure the protection of patient and employee data: in particular, the adoption of automatic alerts for detecting any anomalies and procedures that require the automatic logging of all accesses and operations performed, including even simple consultations of the dossier.

****Insurance: heirs can know the beneficiaries of policies****

****Companies must first verify a series of requirements****

Insurance companies must allow heirs, upon request, access to the names of beneficiaries indicated in policies taken out during the lifetime of deceased individuals.

This was clarified by the Privacy Authority, with a provision set to be published in the Official Gazette, following numerous requests (reports, complaints, and requests for opinions) received due to conflicting decisions made by the courts. These decisions have indeed generated various interpretative doubts over time.

Before transmitting the names, companies must verify that a series of conditions are met. Firstly, they must ascertain that the requester has been duly indicated as an heir or "called to the inheritance," meaning they are entitled to accept the inheritance and thus become an heir. Secondly, they must verify that the interest pursued by the requester is concrete and current (i.e., existing at the time of access to the data), prior to or functional to their defense in court.

The Authority, in expressing its position, stated that the right to privacy must always be balanced with other fundamental rights (such as the right to defense in court), as established by the Charter of Fundamental Rights of the European Union, the Guidelines on the "exercise of the right of access" from the Committee that gathers all EU Data Protection Authorities (EDPB), and by the same case law.

****Civil status certificates at the Post Office, Privacy Authority approval****

The service will involve municipalities with fewer than 15,000 inhabitants.

The Privacy Authority has approved the draft decree from the Minister of the Interior, which, as part of

the "Polis - citizenship service houses" project...

****Digital Certificates**** - provides for the issuance of certificates available in the National Register of the Resident Population (ANPR) also at the counters of Poste Italiane for citizens of municipalities with fewer than 15,000 inhabitants. The draft decree has been prepared taking into account the indications provided by the Authority during discussions with the Ministry of the Interior, aimed at ensuring compliance with the regulations on personal data protection.

The text specifically provides that the civil status certificates of those registered in the ANPR, concerning the applicant and the members of their household, may be requested electronically through the services of Poste Italiane, and issued exclusively by employees of Poste authorized to access the "Polis Platform." In this regard, the operators responsible for issuing the certificates must comply with specific identification and authentication processes, including the use of cryptographic smart cards. Access to the platform will also be recorded and retained for a period of 36 months, ensuring traceability of the operations carried out.

To request the certificate, citizens must go in person to the dedicated counters of Poste Italiane and will be identified by presenting their tax code and an identification document. Once the identity of the applicant has been verified, the Poste operator may proceed with printing the certificate.

In giving its favorable opinion, the Authority deemed the technical, organizational, and security measures for the protection of personal data provided in the draft decree and identified in the impact assessment to be adequate.

****Privacy Authority Warns Osteopath: In Thesis, Patient's Health Data****

Those working in the healthcare sector must always maintain professional secrecy and respect the privacy of their patients by not disclosing health information acquired within the medical-patient trust relationship. This was reiterated by the Privacy Authority in warning an osteopath who had violated privacy regulations and the medical ethics code by including information about a patient's health in a thesis prepared at the conclusion of a training course. The violation was reported to the Authority by the patient herself. In the thesis, in particular, a clinical document containing numerous details about the patient's health status was included, with the personal data being roughly erased, such that it did not prevent the identification of her name and surname and thus the association of personal information with her physical condition.

In this regard, the Privacy Authority reminded that manual deletion procedures are not suitable for anonymizing a patient's personal data and therefore do not guarantee confidentiality. The doctor should have implemented appropriate technical measures to prevent the identification, even indirectly, of the individual concerned.

From the Authority's findings, it also emerged that the osteopath had not obtained the complainant's consent to use her data for purposes other than those of care, such as educational purposes. In the information provided to her patients, the osteopath merely indicated—generically and non-transparently—that the data could be disseminated for "scientific research" purposes. For this reason, the Privacy Authority ordered the doctor to modify and supplement the information model based on the critical elements identified in the provision related to the legal bases of processing, including any transfer of data to third countries and the retention period. The lack of such measures consequently resulted in the communication of the complainant's health data to the training school in the absence of an appropriate legal basis. Considering that the data had not been published, the Authority classified the conduct as a minor violation and therefore warned the osteopath.

****THE ACTIVITIES OF THE AUTHORITY - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority
Artificial Intelligence: Privacy Authority opens an investigation into the collection of personal data online to train algorithms. The initiative aims to verify the adoption of security measures by public and

private websites – Press Release of November 22, 2023.

****NEWSLETTER of the Privacy Authority****

(Registered at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and Editorial Office: Privacy Authority, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it